Machine Learning Basics

CompTIA SecAI+ | Section 2: Introduction to AI Types and Techniques

What Machine Learning Actually Is

Machine learning is a sub-field of artificial intelligence in which systems improve their performance on a task through exposure to data, without being explicitly programmed with rules for that task. The distinction matters enormously in security contexts: a rule-based intrusion detection system must be updated every time attackers change their tactics. An ML-based system, trained on behavioural patterns rather than signatures, continues to function as tactics evolve as long as the underlying behaviour remains detectable.

The formal definition often cited is Tom Mitchell's (1997): A computer program is said to learn from experience E with respect to some task T and performance measure P, if its performance at T, as measured by P, improves with experience E. Breaking this down for security: T might be 'identify compromised accounts', E is historical user behaviour logs, and P is the F1 score on a held-out validation set.

The Three Core Concepts in Depth

Concept	Technical Definition	Security Example	Common Pitfalls
Training	Process of adjusting model parameters by minimising a loss function over labelled or unlabelled examples	Exposing a spam classifier to 500,000 labelled emails	Overfitting: model memorises training data rather than learning generalisable patterns
Model	Mathematical function parameterised by weights learned during training; maps inputs to outputs	A trained neural network that scores each email for spam probability	Model drift: deployed model accuracy degrades as real-world data distribution shifts from training data
Inference	Applying the trained model to new, unseen data to produce predictions	The spam filter scoring each incoming email in real time	Adversarial inputs: attackers craft inputs designed to fool the model during inference

A critical operational distinction: training is computationally expensive and happens infrequently, taking hours to days. Inference must be fast at the millisecond scale and happens continuously in production at high volume. Security teams often confuse these phases, leading to incorrect assumptions about when a model can adapt to new threats.

The Three Types of Machine Learning

The three major ML paradigms each suit different security problems. Selecting the wrong type for a problem is a common implementation failure.

Type	Training Signal	What It Learns	Security Use Cases	Limitation
Supervised Learning	Labelled examples (input to correct output provided)	A mapping from inputs to predefined output categories or values	Spam classification, malware classification, phishing URL detection, fraud scoring	Requires large labelled datasets; blind to attack types not represented in training labels
Unsupervised Learning	No labels; raw data only	Natural clusters, patterns, or compressed representations in the data	Anomaly detection, network traffic clustering, insider threat detection, dark web topic modelling	Difficult to interpret; an interesting cluster does not equal a malicious cluster without domain knowledge
Reinforcement Learning	Reward signal from environment after each action	A policy describing which action maximises cumulative reward in each state	Automated penetration testing, adaptive firewall rule generation, autonomous threat hunting agents	Training instability; reward hacking; slow convergence; safety concerns in live environments

Supervised Learning in Security: Spam and Malware Detection

Supervised learning is the dominant paradigm in current production security tools. The core workflow follows a consistent pattern.

- Data collection: Gather historical examples with ground-truth labels such as malicious or benign, spam or legitimate. Label quality is the single greatest determinant of model quality.
- Feature engineering: Transform raw data such as email text, binary file bytes, or network packets into numerical representations the model can process. Classic spam features include word frequencies (TF-IDF vectors), sender reputation scores, link count, HTML ratio, and DKIM pass or fail status.
- Training: Split data into training and validation sets, typically 80/20. Train the model on the training set and tune hyperparameters based on validation performance.
- Evaluation: Measure on a held-out test set. Critical metrics are precision, recall, F1 score, and ROC-AUC.
- Deployment: Serve the model in production. Monitor for drift, which is the statistical difference between the data the model was trained on and the data it now sees.

Malware classification extends this pattern to binary analysis. Static features include file entropy indicating packing or encryption, import table analysis of which Windows API calls the binary imports, section name abnormalities, and string patterns. Dynamic features captured in sandbox execution include file system modifications, registry changes, network connections, and process injection attempts.

Why ML Beats Signature-Based Detection

The fundamental limitation of signature-based security tools is that they can only detect known threats. Attackers have long exploited this with polymorphic and metamorphic techniques.

- Polymorphic malware: Encrypts its payload with a different key each iteration, changing the binary signature while the functional behaviour remains identical.
- Metamorphic malware: Rewrites its own assembly code using equivalent instruction sequences, obfuscators, and dead-code insertion, producing functionally identical but syntactically different binaries that evade hash-matching.
- Living-off-the-land attacks: Use legitimate, pre-installed system tools such as PowerShell, WMI, and cmd.exe for malicious purposes, leaving no malware binary to signature-match.

ML-based detection focuses on behaviour (what code does) rather than identity (what code looks like). A ransomware binary that renames and encrypts thousands of files in rapid succession exhibits that behaviour regardless of its binary signature, and a behaviour-based ML model catches it. This is why EDR platforms that adopted ML-based behavioural detection significantly outperform legacy antivirus on novel threats.

User and Entity Behaviour Analytics (UEBA) in Depth

UEBA is one of the most strategically important applications of ML in enterprise security. Its core insight is that identities have consistent behavioural signatures: a specific user's working patterns, data access habits, application usage, and communication graphs are statistically stable over time. Deviations from that baseline are signals worth investigating.

Behavioural Dimension	What UEBA Tracks	Attack Pattern It Detects
Authentication	Login times, geolocations, IP addresses, device fingerprints, MFA usage patterns	Account takeover, credential stuffing, impossible travel (login from two geographies within minutes)
Data Access	Which files, databases, or repositories are accessed, volume transferred, timing, and data sensitivity tier	Data exfiltration, ransomware pre-staging, insider theft
Application Usage	Which apps are used, in what sequence, and with what network destinations	Lateral movement, use of shadow IT, command-and-control beaconing
Communication Graph	Email recipients, collaboration tool channels, communication partner patterns	Business email compromise, unusual external communications, internal collusion
Privilege Usage	Which elevated permissions are invoked, on which systems, and at what times	Privilege escalation, pass-the-hash attacks, service account abuse

Real-World Incident — Tesla Insider Threat (2018): A disgruntled Tesla employee used their legitimate credentials to exfiltrate gigabytes of proprietary manufacturing data and make damaging code changes. UEBA-style behavioural analysis that tracked anomalous data download volumes and off-hours access

patterns would have been positioned to flag this activity before significant damage occurred.

Network Intrusion Detection with ML

Network-based intrusion detection has evolved from pattern-matching against a fixed rule set to ML-driven anomaly detection that learns what normal traffic looks like for each unique network environment.

Key features ML models analyse in network traffic include inter-arrival times between packets, because beaconing malware produces unnaturally regular patterns; flow duration and byte volume distribution; protocol compliance issues such as HTTP traffic carrying non-HTTP payloads; DNS query patterns, because DGA-generated domains have measurably different entropy profiles from human-readable domains; and geographic diversity of destination IPs.

A critical operational consideration: network ML models must be trained on the target organisation's own traffic baseline, not a generic public dataset. A university network dominated by academic peer-to-peer traffic looks nothing like a financial services network dominated by API calls and database queries. A model trained on the wrong baseline will generate excessive false positives and be rejected by analysts, a failure mode that results in the tool being disabled rather than tuned.

Predictive Security Analytics and Risk Prioritisation

ML enables a shift from reactive security, which detects attacks that have already occurred, to predictive security, which identifies the highest-risk targets before they are attacked. Predictive models for vulnerability management and attack surface prioritisation consider several factors.

- Vulnerability characteristics: CVSS score, exploit availability in public databases, exploit code maturity from proof-of-concept to weaponised, and time since public disclosure.
- Asset exposure: Internet-facing versus internal placement, network segmentation, and number of inbound firewall rules permitting access.
- Threat intelligence alignment: Active exploitation campaigns targeting this CVE in the wild and threat actor TTPs associated with similar vulnerabilities.
- Business context: The asset's role in critical business processes, data sensitivity tier, and regulatory compliance obligations.

The practical outcome is that a security team drowning in CVEs can now focus the first 20 percent of remediation effort on the 80 percent of actual risk, a direct application of ML-enabled prioritisation.

Automated Threat Hunting with ML

Traditional threat hunting requires a senior analyst to hypothesise an attack technique, write detection logic, and manually query terabytes of log data, a process that can take days or weeks per hypothesis. ML transforms this in two ways.

- Hypothesis generation: ML models can surface statistically unusual patterns in logs that human analysts would never think to query, effectively generating new hunting hypotheses automatically.

- Hypothesis validation: Once a hypothesis exists, ML models can scan months of historical data across multiple log sources in minutes, correlating events that span different systems and time periods.

Advanced persistent threats specifically design their operations to remain below the threshold of alerting individual security tools. They operate slowly, use legitimate credentials and tools, and avoid obvious indicators. The pattern only becomes visible when hundreds of low-confidence signals across months are correlated. ML-powered threat hunting is specifically designed for this correlation task.

> **Learner Warning:** ML-based security tools are not set and forget. They require ongoing monitoring for model drift, alert threshold tuning, and retraining as organisational environments and threat actor TTPs evolve. Deploying an ML security tool without an operational plan for maintenance is a common and costly implementation failure.

Model Performance Metrics for Security Professionals

Security professionals evaluating or deploying ML tools must understand the key metrics that determine whether a model is actually useful in production.

Metric	Formula	Security Interpretation	Optimisation Trade-off
Precision	True Positives / (True Positives + False Positives)	Of all alerts generated, what fraction are real threats?	High precision means fewer false positives and less analyst alert fatigue
Recall (Sensitivity)	True Positives / (True Positives + False Negatives)	Of all real threats, what fraction did the model catch?	High recall means fewer missed attacks but potentially more false positives
F1 Score	2 x (Precision x Recall) / (Precision + Recall)	Balanced measure; preferred when alert volume and miss rate both matter	Neither precision nor recall dominates; useful for comparing models overall
False Positive Rate	False Positives / (False Positives + True Negatives)	Rate of legitimate events incorrectly flagged as threats	SOC teams tune thresholds to keep FPR below analyst capacity
ROC-AUC	Area under the Receiver Operating Characteristic curve	Model's ability to discriminate threats from non-threats across all thresholds	AUC above 0.9 is typically required for production security tools

Model Drift and Operational Maintenance

A deployed ML model degrades over time as the statistical properties of real-world data diverge from the training distribution. In security, this drift can be caused by several factors.

- Organisational change: New business applications, cloud migrations, remote work policies, and mergers and acquisitions all alter what normal network and user behaviour looks like.

- Threat actor evolution: Attackers adapt TTPs in response to detection. A UEBA model trained to detect a specific lateral movement technique may become less effective as attackers shift to different tooling.
- Seasonal variation: Many organisations see legitimate behavioural differences during quarter-end, annual audits, or holiday periods that can trigger false positives if the model was not trained on seasonal data.

Operational best practice: establish a model monitoring pipeline that tracks alert volume, false positive rate, and validation set accuracy on a scheduled cadence. Set automated alerts when metrics degrade beyond defined thresholds. Implement a model retraining schedule that incorporates recent confirmed true positives and true negatives as new labelled data.

Key Terms Glossary

Term	Definition
Machine Learning (ML)	AI sub-field where systems improve performance through data exposure without explicit programming of rules
Supervised Learning	ML where models are trained on labelled input-output pairs to learn a mapping function
Unsupervised Learning	ML where models find patterns in unlabelled data without predefined output categories
Reinforcement Learning	ML paradigm where an agent learns by maximising cumulative reward signals from environmental interaction
Training	Process of adjusting model parameters to minimise a loss function over a dataset
Inference	Applying a trained model to new data to generate predictions; must occur at production speed
Model Drift	Gradual degradation of model accuracy as real-world data distribution diverges from training distribution
UEBA	User and Entity Behaviour Analytics; ML-based detection of anomalous behaviour patterns indicating compromise or insider threat
Polymorphic Malware	Malware that encrypts its payload with a different key each iteration to evade signature matching
Feature Engineering	Process of transforming raw data into numerical representations suitable for ML model training
False Positive Rate	Proportion of legitimate events incorrectly classified as threats; primary driver of SOC analyst alert fatigue
ROC-AUC	Area under the Receiver Operating Characteristic curve; measures a model's discriminative ability across all classification thresholds
Threat Hunting	Proactive search for hidden threats in an environment; ML accelerates hypothesis generation and validation

Quick Revision Checklist

- I can explain what machine learning is and why it differs from rule-based programming
- I understand the three core ML concepts: training, model, and inference, including their timing and cost differences
- I can describe supervised, unsupervised, and reinforcement learning with a security use case for each
- I understand why ML-based malware detection outperforms signature-based approaches against polymorphic threats
- I can explain how UEBA builds behavioural baselines and what deviations it detects
- I understand why network ML models must be trained on organisation-specific baselines
- I can name at least three behavioural dimensions that UEBA tracks and what attack patterns each detects
- I can interpret precision, recall, F1 score, and ROC-AUC in the context of security tool evaluation
- I understand what model drift is and can name three causes specific to security environments
- I understand how predictive ML changes vulnerability prioritisation from reactive to proactive
- I can explain how ML-powered threat hunting detects APTs that evade individual tool detections

20 Exam-Based MCQs — Machine Learning Basics

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Which property of machine learning makes it fundamentally more resilient than signature-based detection against novel malware?

A. ML models update their signatures automatically when new malware is discovered

B. ML models learn behavioural patterns from examples, allowing them to detect threats whose code signatures have never been seen

C. ML models require no training data and can detect threats immediately upon deployment

D. ML models are immune to adversarial manipulation because they use mathematical optimisation

Answer: B **Explanation:** Correct: ML models trained on behavioural features (what code does, not what it looks like) can detect novel variants because the behaviour such as file encryption, process injection, and network beaconing persists even as signatures change. Option A is incorrect because ML models do not update by downloading signature files. Option C is false because all ML models require training data. Option D is the opposite of true because ML models are specifically vulnerable to adversarial inputs.

Q2. A SOC deploys a UEBA system. On day one, it generates 500 alerts, far more than analysts can investigate. What is the MOST likely cause?

A. The model has been trained on too little data

B. The model has not yet established an accurate behavioural baseline; false positives will reduce as the model learns normal patterns

C. UEBA systems are inherently unreliable and should not be deployed in production

D. The organisation's network has an unusually high number of compromised accounts

Answer: B **Explanation:** Correct: UEBA systems require a baseline learning period, typically 2 to 4 weeks,

during which they observe and model normal behaviour. Alerts generated before the baseline is stable are largely false positives from the model's incomplete understanding of what is normal. The solution is to allow baseline stabilisation, not to abandon the tool. Option A could contribute but is not the primary framing. Option C is false because UEBA is a validated production technology. Option D is possible but not the expected cause.

Q3. What distinguishes the training phase from the inference phase in a production security ML deployment?

A. Training uses raw data; inference uses pre-processed features

B. Training is computationally expensive and infrequent; inference is fast and happens millions of times in production

C. Training requires labelled data; inference requires unlabelled data

D. Training occurs on the cloud; inference always occurs on the endpoint

Answer: B **Explanation:** Correct: Training is resource-intensive and occurs periodically. Inference must be fast at the millisecond scale and occurs at scale in production where a spam filter may run inference on millions of emails per day. Option A is incorrect because both phases work with features. Option C is a generalisation that applies only to supervised learning. Option D is false because deployment architecture varies widely.

Q4. A security team discovers that their ML-based intrusion detection system now generates an unusually high false positive rate following the company's migration to a cloud-based SaaS productivity suite. What is MOST likely occurring?

A. The model's encryption keys have expired

B. The model is experiencing drift — the traffic patterns from SaaS tools differ from the on-premise baseline the model was trained on

C. The cloud provider is deliberately injecting false alerts to sell premium services

D. Unsupervised ML models always degrade after 90 days of operation

Answer: B **Explanation:** Correct: Cloud SaaS traffic with continuous API calls to cloud endpoints, different DNS patterns, and new IP ranges is statistically different from the on-premise network profile the model was trained on. This distribution shift causes the model to flag legitimate new traffic as anomalous, which is classic model drift. Option A is not a real ML operational issue. Option C is implausible. Option D is false because drift timelines depend on environmental change rate, not a fixed timer.

Q5. An ML system flags a senior engineer who downloaded 40 GB of source code in one afternoon. Investigation reveals the engineer was given a new project requiring access to the full codebase and this was their first day on the project. Which ML performance outcome does this represent?

A. True positive — a real threat was correctly detected

B. False negative — a real threat was missed

C. False positive — a legitimate action was incorrectly flagged as a threat

D. True negative — a legitimate action was correctly cleared

Answer: C **Explanation:** Correct: The engineer's behaviour was legitimate but anomalous relative to their historical baseline. The model generated an alert (positive classification) but the underlying event was not malicious, making it a false positive. This illustrates the fundamental trade-off in anomaly detection: unusual does not equal malicious. A true positive (A) would require the download to be actual exfiltration. A false negative (B) is a missed threat. A true negative (D) would mean no alert was generated for legitimate activity.

Q6. Which type of machine learning is MOST appropriate for discovering previously unknown attack patterns in unlabelled network traffic logs?

A. Supervised learning, because it produces the most accurate classifications

B. Reinforcement learning, because it can adapt to attacker behaviour in real time

C. Unsupervised learning, because it groups similar traffic patterns without requiring predefined attack labels

D. Transfer learning, because it reuses labels from similar networks

Answer: C **Explanation:** Correct: Unsupervised clustering techniques can group traffic by statistical similarity and surface outlier clusters that do not fit known normal patterns, which is useful for discovering novel attack traffic without predefined labels. Supervised learning (A) requires labelled examples. Reinforcement learning (B) is designed for sequential decision-making agents, not batch log analysis. Transfer learning (D) is a training technique, not a paradigm that bypasses label requirements.

Q7. A penetration testing tool uses reinforcement learning to autonomously probe a network, testing exploits, and adaptively selecting next steps. What is the PRIMARY risk of deploying such a tool in a live production environment without proper guardrails?

A. The tool will drain network bandwidth and cause latency for end users

B. Reinforcement learning agents can take unexpected, high-impact actions while optimising their reward function, potentially causing service disruptions or triggering real security incidents

C. The tool cannot operate on encrypted network segments

D. Reinforcement learning is too slow to be useful for penetration testing

Answer: B **Explanation:** Correct: RL agents optimise for their reward function, but if the reward function does not perfectly capture all constraints such as avoiding crashes of production services or preventing data loss, the agent may take actions that are optimal for the reward but catastrophic in practice. This reward hacking risk is why RL-based security tools must be tested in isolated environments with human oversight before any production use.

Q8. Why must an ML-based network anomaly detection model be trained on the target organisation's own traffic rather than a generic public dataset?

A. Public datasets are copyrighted and cannot be used commercially

B. Each organisation's normal traffic has a unique statistical profile; a model trained on generic data will flag the organisation's legitimate normal traffic as anomalous

C. Generic public datasets do not contain any labelled attack traffic

D. Training on the organisation's data is required to comply with GDPR

Answer: B **Explanation:** Correct: Network traffic baselines are organisation-specific. A financial services firm's traffic looks radically different from a university's. A model trained on the wrong baseline will misclassify large volumes of legitimate traffic as anomalous, making it operationally useless due to alert fatigue. Option A is not a technical ML constraint. Option C is false because public datasets like CICIDS and KDD Cup do contain labelled attacks. Option D is a compliance consideration, not a technical ML reason.

Q9. A security vendor claims their ML malware classifier achieves 99% accuracy on their benchmark dataset. What additional metric is MOST important to evaluate before deploying it in an environment where 1 in 10,000 files is malicious?

A. The number of training epochs used

B. The vendor's annual revenue

C. The false positive rate and precision, because with a 0.01% malware base rate, even a 99% accurate model generates vast numbers of false positives

D. Whether the model uses supervised or unsupervised learning

Answer: C **Explanation:** Correct: In highly imbalanced datasets with very low malware prevalence, accuracy is a misleading metric. A model that classifies everything as benign achieves 99.99% accuracy while detecting zero malware. What matters is precision and false positive rate. With a 0.01% base rate, even a small FPR generates enormous absolute alert volumes. Options A and B are irrelevant. Option D is a design consideration but secondary to operational metrics.

Q10. Which UEBA anomaly would MOST strongly indicate a credential-based account takeover rather than an insider threat?

A. The user downloads unusually large volumes of data on a Friday afternoon

B. The user accesses sensitive project files they have not previously accessed

C. A successful login occurs from a geolocation physically impossible to reach given the user's previous login 30 minutes earlier

D. The user installs an unapproved application on their workstation

Answer: C **Explanation:** Correct: Impossible travel, where a login from a geolocation cannot be reached in the time elapsed since the previous authenticated session, is a high-fidelity indicator of credential compromise, since a legitimate user cannot physically be in two geographically separated locations within minutes. The other options could represent insider threat behaviour or legitimate unusual activity, but they lack the near-certainty of impossible travel as a credential compromise indicator.

Q11. An ML model detects malware by analysing what processes do at runtime rather than static binary signatures. This approach is MOST effective against which threat category?

A. Known malware with stable signatures in the AV database

B. Polymorphic and metamorphic malware that changes its code to evade hash-matching

C. Social engineering attacks that do not involve any code execution

D. Phishing emails that arrive before any code is executed on the endpoint

Answer: B **Explanation:** Correct: Behavioural analysis detects malware based on what it does, not what it looks like, making it effective against polymorphic and metamorphic variants that change their binary signature while maintaining the same malicious behaviour. Known malware with stable signatures (A) is actually easier to catch with signatures. Social engineering (C) and phishing email detection (D) occur before or without code execution and require different detection mechanisms.

Q12. A threat intelligence team uses ML to correlate thousands of low-confidence security events across 14 months of logs and identifies a nation-state APT that had been operating undetected. Which ML capability was MOST responsible for this discovery?

A. Real-time signature matching against known APT indicators

B. Supervised classification trained on APT-labelled historical data

C. Unsupervised pattern correlation across multi-source, multi-month log data, surfacing statistical anomalies invisible to manual analysis

D. Reinforcement learning agents that proactively probed the network for indicators

Answer: C **Explanation:** Correct: APT detection spanning 14 months of data across multiple log sources — correlating tiny, individually insignificant signals into a coherent attack pattern — is exactly what ML-powered unsupervised analysis excels at. Signature matching (A) would not work because the APT used novel techniques. Supervised classification (B) requires labelled APT examples from this specific environment. RL agents (D) are for active probing, not retrospective log analysis.

Q13. What does overfitting mean in the context of a security ML model, and what is its practical consequence?

A. The model trains on too many examples and becomes too slow for production inference

B. The model memorises the training data instead of learning generalisable patterns, resulting in poor performance on new real-world data

C. The model generates too many output features, making it difficult to interpret

D. The model is updated too frequently, causing it to forget previous threats

Answer: B **Explanation:** Correct: An overfitted model has essentially memorised the specific examples in its training set rather than learning underlying patterns that generalise to new data. In security, this means the model achieves near-perfect accuracy in testing but fails in production because real attack traffic does not exactly match training examples. Option A describes computational performance. Option C describes interpretability. Option D describes a retraining concern, not overfitting.

Q14. A financial services firm wants to prioritise which of their 8,000 known vulnerabilities to patch first. Which ML approach MOST effectively enables data-driven prioritisation beyond CVSS score alone?

A. Signature-based detection of active exploitation on their network

B. A predictive risk model that incorporates CVSS score, active exploitation availability, asset exposure, business criticality, and current threat intelligence

C. Manual penetration testing of each vulnerable system

D. Sorting vulnerabilities by CVE number, as older CVEs have had more time to be exploited

Answer: B **Explanation:** Correct: Predictive prioritisation ML models that combine multiple contextual factors have been shown to dramatically improve patch prioritisation, concentrating effort on vulnerabilities most likely to be exploited given an organisation's specific environment and current threat actor activity. Signature-based detection (A) identifies active exploitation after the fact. Manual pen testing (C) at scale of 8,000 vulnerabilities is impractical. CVE number sorting (D) has no relationship to exploitation likelihood.

Q15. Domain Generation Algorithms used by malware generate pseudo-random domain names for C2 communication. Which ML feature BEST enables detection of DGA-generated domains?

A. Blacklist matching against known malicious domains

B. Measuring entropy (randomness) of domain name character sequences, since DGA domains have measurably higher entropy than human-readable domains

C. Checking WHOIS registration date, as DGA domains are always newly registered

D. Monitoring for domains with more than 15 characters

Answer: B **Explanation:** Correct: DGA-generated domains consist of pseudo-random character sequences with significantly higher entropy than human-readable domains. ML models trained on entropy-based and n-gram frequency features can distinguish DGA traffic from legitimate DNS queries. Blacklist matching (A) fails for newly generated domains not yet on blacklists, which is the core reason DGAs exist. WHOIS date (C) is a weak heuristic that is easily defeated. Character length (D) would generate enormous false positives.

Q16. A SOC manager adjusts the ML classification threshold to flag only higher-confidence events, reducing daily alert volume from 2,000 to 180. What trade-off has been made?

A. Precision increased; recall likely decreased — some real threats will now be missed

B. Precision decreased; recall increased — more false positives will appear in the reduced alert set

C. Both precision and recall increased — raising the threshold strictly improves performance

D. Alert volume decreased; no change to detection accuracy

Answer: A **Explanation:** Correct: Raising the classification threshold reduces false positives and increases precision, but events that were previously detected at lower confidence thresholds may now fall below the new threshold and be missed, reducing recall. This is the fundamental precision-recall trade-off in classification systems. Option B is incorrect because raising the threshold reduces false positives, which improves precision. Option C is false because the trade-off is one-directional. Option D is false because the

threshold change directly affects which events are classified as threats.

Q17. Which of the following BEST describes living-off-the-land attacks, and why do they challenge ML-based behavioural detection?

A. Attacks that use custom malware with unique signatures, making static analysis impossible

B. Attacks that use only pre-installed, legitimate system tools such as PowerShell and WMI for malicious purposes, making it difficult to distinguish malicious from administrative activity

C. Attacks that operate exclusively over encrypted channels to evade network inspection

D. Attacks that target IoT devices embedded in building management systems

Answer: B **Explanation:** Correct: Living-off-the-land attacks leave no malware binary to detect and use the same tools that legitimate administrators use, creating significant overlap between malicious and benign behaviour. ML-based detection must model the context, sequence, and timing of tool usage to distinguish malicious from legitimate administrative activity, which is substantially harder than detecting novel malware binaries.

Q18. An ML security model is described as achieving an ROC-AUC of 0.74. How should a security analyst interpret this?

A. The model correctly classifies 74% of all events

B. The model's ability to discriminate threats from non-threats across all thresholds is moderate — typically insufficient for production security deployment, where values above 0.9 are preferred

C. The model generates false positives on 26% of events

D. The model detects 74% of all attacks in the dataset

Answer: B **Explanation:** Correct: ROC-AUC measures discriminative ability across all possible classification thresholds, where 0.5 is random and 1.0 is perfect. A value of 0.74 indicates the model is better than random but has limited discriminative power. Production security tools typically require AUC above 0.9 to keep false positive rates manageable at operational alert volumes. Option A confuses AUC with accuracy. Option C confuses AUC with false positive rate. Option D confuses AUC with recall.

Q19. A security team's ML anomaly detection model was trained 18 months ago. The organisation has since adopted remote work, moved 60% of workloads to AWS, and onboarded 300 new employees. What should the team do FIRST?

A. Increase the alert threshold to reduce false positives

B. Retrain or fine-tune the model on recent data that reflects current organisational patterns, as the training distribution has significantly drifted from current operations

C. Purchase a new commercial ML security product to replace the existing model

D. Disable the model until a formal risk assessment of model drift is completed

Answer: B **Explanation:** Correct: The organisation's environment has changed dramatically across multiple dimensions. The model's training distribution is now substantially different from current operations, meaning its anomaly detection is calibrated to an environment that no longer exists. Retraining

on recent data is the appropriate technical response. Raising the threshold (A) treats the symptom rather than the cause. Purchasing a new product (C) is expensive and does not solve the retraining problem. Disabling the model (D) eliminates detection capability unnecessarily.

Q20. A company's ML-based spam filter achieves 98% recall but generates 500 false positive alerts per day across 10,000 employees. What is the MOST appropriate operational response?

A. Accept the false positive rate as a reasonable trade-off for high recall

B. Disable the ML filter and revert to a rule-based system

C. Tune the classification threshold and feature weights to reduce false positives, accepting slightly lower recall, while creating a user-friendly false positive reporting mechanism

D. Increase the training dataset size to reduce false positives without affecting recall

Answer: C **Explanation:** Correct: 500 false positives per day creates significant operational burden including missed legitimate emails, helpdesk tickets, and lost productivity. Threshold tuning that reduces FPR while accepting marginally lower recall is the standard operational response, combined with a user-reporting mechanism that creates labelled data for future retraining. Option A ignores the operational impact. Option B unnecessarily discards a productive ML capability. Option D is incorrect because simply adding training data does not guarantee FP reduction without additional threshold or feature adjustments.